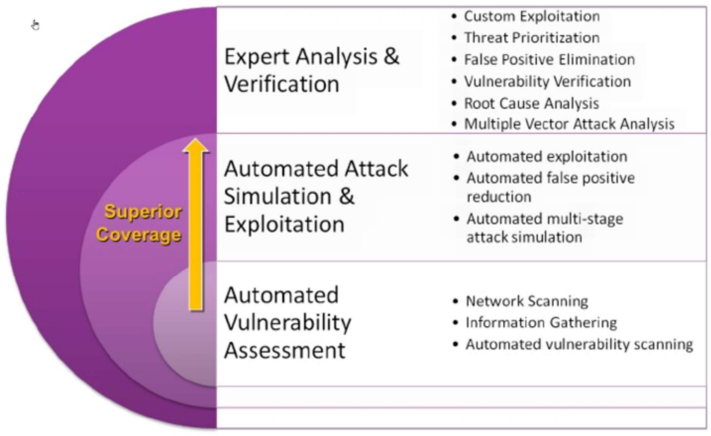
Test-Coverage Analysis



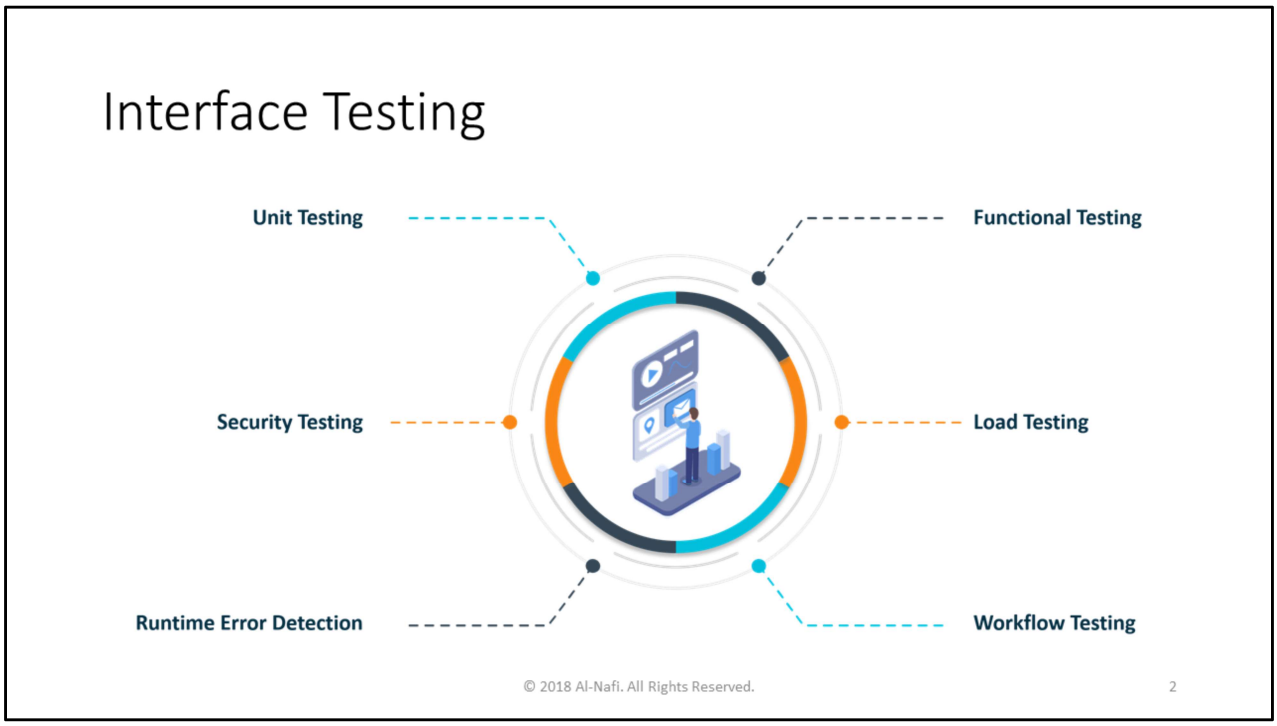
© 2018 Al-Nafi. All Rights Reserved.

Test-Coverage Analyzers

Test-coverage analyzers measure how much of the total program code has been analyzed. The results can be presented in terms of statement coverage (percentage of lines of code tested) or branch coverage (percentage of available paths tested).

For large applications, acceptable levels of coverage can be determined in advance and then compared to the results produced by test-coverage analyzers to accelerate the testing-and-release process. These tools can also detect if particular lines of code or branches of logic are not actually able to be reached during program execution, which is inefficient and a potential security concern. Some SAST tools incorporate this functionality into their products, but standalone products also exist.

Since the functionality of analyzing coverage is being incorporated into some of the other AST tool types, standalone coverage analyzers are mainly for niche use.



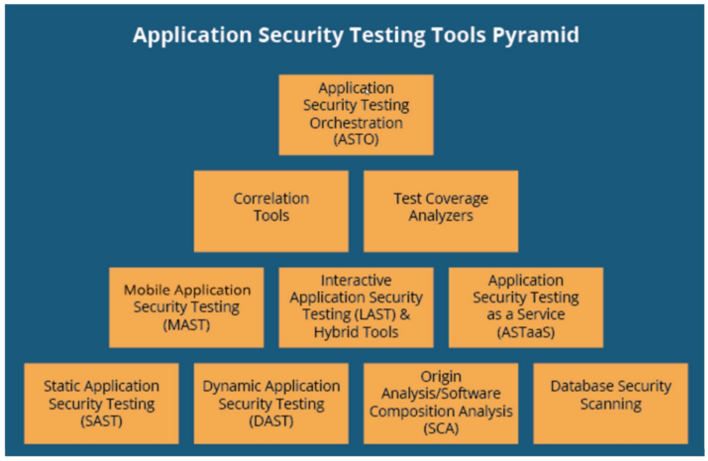
Interface testing involves the testing of the different components of an application, e.g., software and hardware, in combination. This kind of combination testing is done to ensure they are working correctly and conforming to the requirements based on which they were designed and developed. Interface testing is different from integration testing in that interface testing is done to check whether the different components of the application or system being developed are in sync with each other. In technical terms, interface testing helps determine that distinct functions, such as data transfer between the different elements in the system, are happening according to the way they were designed to happen.

Interface testing is one of the most important software tests in assuring the quality of software products. Interface testing is conducted to evaluate whether systems or components pass data and control correctly to one another. Interface testing is usually performed by both testing and development teams. Interface testing helps to determine which application areas are accessed as well as their user-friendliness.

Interface testing can be used to do the following:

- Check and verify if all the interactions between the application and a server are executed properly
- Check and verify if errors are being handled properly
- Check what happens if a user interrupts any transaction
- Check what happens if a connection to a web server is reset

Application Security Testing tools Pyramid



© 2018 Al-Nafi. All Rights Reserved. 3

10 Types of Application Security Testing Tools: When and How to Use Them
JULY 9, 2018 • SEI BLOG

By Thomas Scanlon

Bugs and weaknesses in software are common: 84 percent of software breaches exploit vulnerabilities at the application layer. The prevalence of software-related problems is a key motivation for using application security testing (AST) tools. With a growing number of application security testing tools available, it can be confusing for information technology (IT) leaders, developers, and engineers to know which tools address which issues. This blog post, the first in a series on application security testing tools, will help to navigate the sea of offerings by categorizing the different types of AST tools available and providing guidance on how and when to use each class of tool.

See the second post in this series, *Decision-Making Factors for Selecting Application Security Testing Tools*.

Application security is not a simple binary choice, whereby you either have security or you don't. Application security is more of a sliding scale where providing additional security layers helps reduce the risk of an incident, hopefully to an acceptable level of risk for the organization. Thus, application-security testing reduces risk in applications, but cannot completely eliminate it. Steps can be taken, however, to remove those risks that are easiest to remove and to harden the software in use.

The major motivation for using AST tools is that manual code reviews and traditional test plans are time consuming, and new vulnerabilities are continually being introduced or discovered. In many domains, there are regulatory and compliance directives that mandate the use of AST tools. Moreover--and perhaps most importantly--individuals and groups intent on compromising systems use tools too, and those charged with protecting those systems must keep pace with their adversaries.

There are many benefits to using AST tools, which increase the speed, efficiency, and coverage paths for testing applications. The tests they conduct are repeatable and scale well--once a test case is developed in a tool, it can be executed against many lines of code with little incremental cost. AST tools are effective at finding known vulnerabilities, issues, and weaknesses, and they enable users to triage and classify their findings. They can also be used in the remediation workflow, particularly in verification, and they can be used to correlate and identify trends and patterns.

Guide to Application Security Testing Tools
This graphic depicts classes or categories of application security testing tools. The boundaries are blurred at times, as particular products can perform elements of multiple categories, but these are roughly the classes of tools within this domain. There is a rough hierarchy in that the tools at the bottom of the pyramid are foundational and as proficiency is gained with them, organizations may look to use some of the more progressive methods higher in the pyramid.

Static Application Security Testing (SAST)
SAST tools can be thought of as white-hat or white-box testing, where the tester knows information about the system or software being tested, including

an architecture diagram, access to source code, etc. SAST tools examine source code (at rest) to detect and report weaknesses that can lead to security vulnerabilities.
Source-code analyzers can run on non-compiled code to check for defects such as numerical errors, input validation, race conditions, path traversals, pointers and references, and more. Binary and byte-code analyzers do the same on built and compiled code. Some tools run on source code only, some on compiled code only, and some on both.

Dynamic Application Security Testing (DAST)
In contrast to SAST tools, DAST tools can be thought of as black-hat or black-box testing, where the tester has no prior knowledge of the system. They detect conditions that indicate a security vulnerability in an application in its running state. DAST tools run on operating code to detect issues with interfaces, requests, responses, scripting (i.e., JavaScript), data injection, sessions, authentication, and more.
DAST tools employ fuzzing: throwing known invalid and unexpected test cases at an application, often in large volume.

Origin Analysis/Software Composition Analysis (SCA)
Software-governance processes that depend on manual inspection are prone to failure. SCA tools examine software to determine the origins of all components and libraries within the software. These tools are highly effective at identifying and finding vulnerabilities in common and popular components, particularly open-source components. They do not, however, detect vulnerabilities for in-house custom developed components.

SCA tools are most effective in finding common and popular libraries and components, particularly open-source pieces. They work by comparing known modules found in code to a list of known vulnerabilities. The SCA tools find components that have known and documented vulnerabilities and will often advise if components are out of date or have patches available.
To make this comparison, almost all SCA tools use the NIST National Vulnerability Database Common Vulnerabilities and Exposures (CVEs) as a source for known vulnerabilities. Many commercial SCA products also use the VulnDB commercial vulnerability database as a source, as well as some other public and proprietary sources. SCA tools can run on source code, byte code, binary code, or some combination.

Database Security Scanning

The SQL Slammer worm of 2003 exploited a known vulnerability in a database-management system that had a patch released more than one year before the attack. Although databases are not always considered part of an application, application developers often rely heavily on the database, and applications can often heavily affect databases. Database-security-scanning tools check for updated patches and versions, weak passwords, configuration errors, access control list (ACL) issues, and more. Some tools can mine logs looking for irregular patterns or actions, such as excessive administrative actions.

Database scanners generally run on the static data that is at rest while the database-management system is operating. Some scanners can monitor data that is in transit.

Interactive Application Security Testing (IAST) and Hybrid Tools

Hybrid approaches have been available for a long time, but more recently have been categorized and discussed using the term IAST. IAST tools use a combination of static and dynamic analysis techniques. They can test whether known vulnerabilities in code are actually exploitable in the running application.

IAST tools use knowledge of application flow and data flow to create advanced attack scenarios and use dynamic analysis results recursively: as a dynamic scan is being performed, the tool will learn things about the application based on how it responds to test cases. Some tools will use this knowledge to create additional test cases, which then could yield more knowledge for more test cases and so on. IAST tools are adept at reducing the number of false positives, and work well in Agile and DevOps environments where traditional stand-alone DAST and SAST tools can be too time intensive for the development cycle.

Mobile Application Security Testing (MAST)

The Open Web Application Security Project (OWASP) listed the top 10 mobile risks in 2016 as

improper platform usage
insecure data storage
insecure communication
insecure authentication
insufficient cryptography

insecure authorization
client code quality
code tampering
reverse engineering
extraneous functionality

MAST Tools are a blend of static, dynamic, and forensics analysis. They perform some of the same functions as traditional static and dynamic analyzers but enable mobile code to be run through many of those analyzers as well. MAST tools have specialized features that focus on issues specific to mobile applications, such as jail-breaking or rooting of the device, spoofed WI-FI connections, handling and validation of certificates, prevention of data leakage, and more.

Application Security Testing as a Service (ASTaaS)

As the name suggests, with ASTaaS, you pay someone to perform security testing on your application. The service will usually be a combination of static and dynamic analysis, penetration testing, testing of application programming interfaces (APIs), risk assessments, and more. ASTaaS can be used on traditional applications, especially mobile and web apps.

Momentum for the use of ASTaaS is coming from use of cloud applications, where resources for testing are easier to marshal. Worldwide spending on public cloud computing is projected to increase from $67B in 2015 to $162B in 2020.

Correlation Tools

Dealing with false positives is a big issue in application security testing. Correlation tools can help reduce some of the noise by providing a central repository for findings from others AST tools.

Different AST tools will have different findings, so correlation tools correlate and analyze results from different AST tools and help with validation and prioritization of findings, including remediation workflows. Whereas some correlation tools include code scanners, they are useful mainly for importing findings from other tools.

Test-Coverage Analyzers

Test-coverage analyzers measure how much of the total program code has been analyzed. The results can be presented in terms of statement coverage (percentage of lines of code tested) or branch coverage (percentage of available

paths tested).
For large applications, acceptable levels of coverage can be determined in advance and then compared to the results produced by test-coverage analyzers to accelerate the testing-and-release process. These tools can also detect if particular lines of code or branches of logic are not actually able to be reached during program execution, which is inefficient and a potential security concern. Some SAST tools incorporate this functionality into their products, but standalone products also exist.
Since the functionality of analyzing coverage is being incorporated into some of the other AST tool types, standalone coverage analyzers are mainly for niche use.

Application Security Testing Orchestration (ASTO)
ASTO integrates security tooling across a software development lifecycle (SDLC). While the term ASTO is newly coined by Gartner since this is an emerging field, there are tools that have been doing ASTO already, mainly those created by correlation-tool vendors. The idea of ASTO is to have central, coordinated management and reporting of all the different AST tools running in an ecosystem. It is still too early to know if the term and product lines will endure, but as automated testing becomes more ubiquitous, ASTO does fill a need.

Selecting Testing Tool Types
There are many factors to consider when selecting from among these different types of AST tools. If you are wondering how to begin, the biggest decision you will make is to get started by beginning using the tools. According to a 2013 Microsoft security study, 76 percent of U.S. developers use no secure application-program process and more than 40 percent of software developers globally said that security wasn't a top priority for them. Our strongest recommendation is that you exclude yourself from these percentages.
There are factors that will help you to decide which type of AST tools to use and to determine which products within an AST tool class to use. It is important to note, however, that no single tool will solve all problems. As stated above, security is not binary; the goal is to reduce risk and exposure.
Before looking at specific AST products, the first step is to determine which type of AST tool is appropriate for your application. Until your application software testing grows in sophistication, most tooling will be done using AST tools from the base of the pyramid, shown in blue in the figure below. These

are the most mature AST tools that address most common weaknesses.
After you gain proficiency and experience, you can consider adding some of the second-level approaches shown below in blue. For instance, many testing tools for mobile platforms provide frameworks for you to write custom scripts for testing. Having some experience with traditional DAST tools will allow you to write better test scripts. Likewise, if you have experience with all the classes of tools at the base of the pyramid, you will be better positioned to negotiate the terms and features of an ASTaaS contract.

The decision to employ tools in the top three boxes in the pyramid is dictated as much by management and resource concerns as by technical considerations. If you are able to implement only one AST tool, here are some guidelines for which type of tool to choose:
If the application is written in-house or you have access to the source code, a good starting point is to run a static application security tool (SAST) and check for coding issues and adherence to coding standards. In fact, SAST is the most common starting point for initial code analysis.
If the application is not written in house or you otherwise don't have access to the source code, dynamic application security testing (DAST) is the best choice.
Whether you have access to the source code or not, if a lot of third-party and open-source components are known to be used in the application, then origin analysis/software composition analysis (SCA) tools are the best choice. Ideally, SCA tools are run alongside SAST and/or DAST tools, but if resources only allow for implementation of one tool, SCA tools are imperative for applications with 3rd party components because they will check for vulnerabilities that are already widely known.

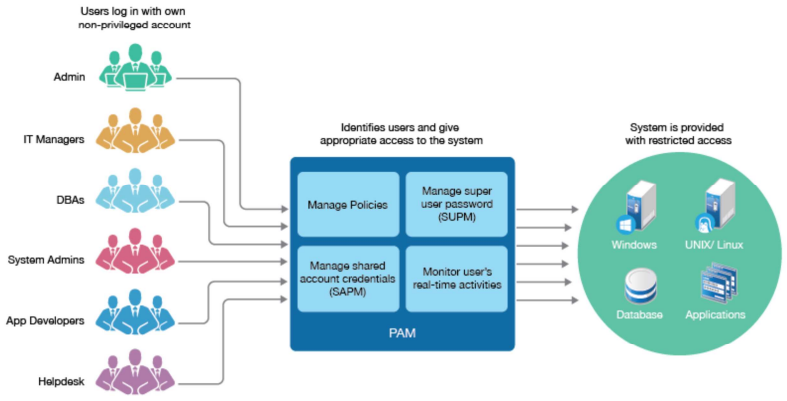
Wrapping Up and Looking Ahead
In the long run, incorporating AST tools into the development process should save time and effort on re-work by catching issues earlier. In practice, however, implementing AST tools requires some initial investment of time and resources. Our guidance presented above is intended to help you select an appropriate starting point. After you begin using AST tools, they can produce lots of results, and someone must manage and act on them.
As you analyze the results with one tool, it may become desirable to introduce additional tools into your environment. As a reference example, the graphic below depicts how many classes of tools could be effectively deployed in

a continuous integration and continuous delivery (CI/CD) development process. It is not intended that all these tools be introduced at once into environment. This graphic shows where certain classes of tools fit in to help you make decisions and to provide a roadmap for where you can get to eventually.

These tools also have many knobs and buttons for calibrating the output, but it takes time to set them at a desirable level. Both false positives and false negatives can be troublesome if the tools are not set correctly.
In the next post in this series, I will consider these decision factors in greater detail and present guidance in the form of lists that can easily be scanned and used as checklists by those responsible for application security testing.

Additional Resources
Read the second post in this series, Decision-Making Factors for Selecting Application Security Testing Tools.
Learn about the National Institute of Standards and Technology (NIST) Software Assurance Metrics and Tool Evaluation (SAMATE) Project.
Learn about the Open Web Application Security Project (OWASP).
Learn about the SANS Institute.
Access and download the software, tools, and methods that the SEI creates, tests, refines, and disseminates.
Review the Department of Homeland Security (DHS) Build Security In website.

Account Management Security



© 2018 Al-Nafi. All Rights Reserved.

Account management supports organizational and mission or business functions by:

- Assigning account managers for information systems accounts.
- Establishing conditions for group or role membership.
- Specifying authorized users of information systems.
- Requiring approval for authorizations, creating, enabling, modifying, disabling, and removing access.
- Monitoring use of information systems accounts.
- Notification to account manager when account access is no longer needed.
- Reviews account for compliance with account management requirements.

Management review



© 2018 Al-Nafi. All Rights Reserved.

9.3 Management review

Top management shall review the organization's information security management system at planned intervals to ensure its continuing suitability, adequacy and effectiveness.

The management review shall include consideration of:

a) the status of actions from previous management reviews;

b) changes in external and internal issues that are relevant to the information security management system;

c) feedback on the information security performance, including trends in:

1) nonconformities and corrective actions;

2) monitoring and measurement results;

3) audit results; and

4) fulfilment of information security objectives;

d) feedback from interested parties;

e) results of risk assessment and status of risk treatment plan; and

f) opportunities for continual improvement.

The outputs of the management review shall include decisions related to continual improvement opportunities and any needs for changes to the information security management system.
The organization shall retain documented information as evidence of the results of management reviews.

Key Performance and Risk Indicators



© 2018 Al-Nafi. All Rights Reserved.

Download this document and read end to end to understand KPI's and KRI's.

https://www.coso.org/Documents/COSO-KRI-Paper-Full-FINAL-for-Web-Posting-Dec110-000.pdf

It is important to distinguish key performance indicators (KPIs) from key risk indicators (KRIs). Both management and boards regularly review summary data that include selected KPIs designed to provide a high-level overview of the performance of the organization and its major operating units. These reports often are focused almost exclusively on the historical performance of the organization and its key units and operations. For example, reports often highlight monthly, quarterly, and year-to-date sales trends, customer shipments, delinquencies, and other performance data points relevant to the organization. It is important to recognize that these measures may not provide an adequate "early warning indicator" of a developing risk because they mostly focus on results that have already occurred.

While KPIs are important to the successful management of an organization by identifying underperforming aspects of the enterprise as well as those aspects of the business that merit increased resources and energy, senior management and boards also benefit from a set of KRIs that provide timely leading-indicator information about emerging risks.

Measures of events or trigger points that might signal issues developing internally within the operations of the organization or potential risks emerging from external events, such as macroeconomic shifts that affect the demand for the organization's products or services, may provide rich information for management and boards to consider as they execute the strategies of the organization.

Key risk indicators are metrics used by organizations to provide an early signal of increasing risk exposures in various areas of the enterprise. In some instances, they may represent key ratios that management throughout the organization track as indicators of evolving risks, and potential opportunities, which signal the need for actions that need to be taken. Others may be more elaborate and involve the aggregation of several individual risk indicators into a multi-dimensional score about emerging events that may lead to new risks or opportunities. An example related to the oversight of accounts receivable collection helps illustrate the difference in KPIs and KRIs. A key performance indicator for customer credit is likely to include data about customer delinquencies and write-offs. This key performance indicator, while important, provides insights about a risk event that has already occurred (e.g., a customer failed to pay in accordance with the sales agreement or contract). A KRI could be developed to help anticipate potential future customer collection issues so that the credit function could be more proactive in addressing customer payment trends before risk events occur. A relevant KRI for this example might be analysis of reported financial results of the company's 25 largest customers or general collection challenges throughout the industry to see what trends might be emerging among customers that could potentially signal challenges related to collection efforts in future periods.

Developing Effective Key Risk Indicators A goal of developing an effective set of KRIs is to identify relevant metrics that provide useful insights about potential risks that may have an impact on the achievement of the organization's objectives. Therefore, the selection and design of effective KRIs starts with a firm grasp of organizational objectives and risk-related events that might affect the achievement of those objectives. Linkage of top risks to core strategies helps pinpoint the most relevant information that might serve as an effective leading indicator of an emerging risk. In the simple illustration below, management has an objective to achieve greater profitability by increasing revenues and decreasing costs. They have identified four strategic initiatives that are critical to accomplishing those objectives. Several potential risks have been identified that may have an impact on one or more of four key strategic initiatives. Mapping key risks to core strategic initiatives puts management in a position to begin identifying the most critical metrics that can serve as leading key risk indicators to help them oversee the execution of core strategic initiatives. As shown below, KRIs have been identified for each critical risk. Mapping KRIs to critical risks and core strategies reduces the likelihood that management becomes distracted by other information that may be less relevant to the achievement of enterprise objectives.

Data Backup and Verification



© 2018 Al-Nafi. All Rights Reserved.

12.3 Backup

Objective: To protect against loss of data.

12.3.1 Information backup

Control

Backup copies of information, software and system images should be taken and tested regularly in accordance with an agreed backup policy.

Implementation guidance

A backup policy should be established to define the organization's requirements for backup of information, software and systems. The backup policy should define the retention and protection requirements.

Adequate backup facilities should be provided to ensure that all essential information and software can be recovered following a disaster or media failure.

When designing a backup plan, the following items should be taken into consideration:

a) accurate and complete records of the backup copies and documented restoration procedures should be produced;
b) the extent (e.g. full or differential backup) and frequency of backups should reflect the business requirements of the organization, the security requirements of the information involved and the
criticality of the information to the continued operation of the organization;
c) the backups should be stored in a remote location, at a sufficient distance to escape any damage from a disaster at the main site;
d) backup information should be given an appropriate level of physical and environmental protection (see Clause 11) consistent with the standards applied at the main site;
e) backup media should be regularly tested to ensure that they can be relied upon for emergency use when necessary; this should be combined with a test of the restoration procedures and checked against the restoration time required. Testing the ability to restore backed-up data should be performed onto dedicated test media, not by overwriting the original media in case the backup or restoration process fails and causes irreparable data damage or loss;
f) in situations where confidentiality is of importance, backups should be protected by means of encryption. Operational procedures should monitor the execution of backups and address failures of scheduled backups to ensure completeness of backups according to the backup policy. Backup arrangements for individual systems and services should be regularly tested to ensure that they meet the requirements of business continuity plans. In the case of critical systems and services, backup arrangements should cover all systems information, applications and data necessary to recover the complete system in the event of a disaster. The retention period for essential business information should be determined, taking into account any requirement for archive copies to be permanently retained.

Training and Awareness



© 2018 Al-Nafi. All Rights Reserved.

Training is defined in NIST Special Publication 800-16 as follows: “The ‘Training’ level of the learning continuum strives to produce relevant and needed security skills and competencies by practitioners of functional specialties other than IT security (e.g., management, systems design and development, acquisition, auditing).” The most significant difference between training and awareness is that training seeks to teach skills, which allow a person to perform a specific function, while awareness seeks to focus an individual’s attention on an issue or set of issues. The skills acquired during training are built upon the awareness foundation, in particular, upon the security basics and literacy material. A training curriculum must not necessarily lead to a formal degree from an institution of higher learning; however, a training course may contain much of the same material found in a course that a college or university includes in a certificate or degree program.

An example of training is an IT security course for system administrators, which should address in detail the management controls, operational

controls, and technical controls that should be implemented. Management controls include policy, IT security program management, risk management, and life-cycle security. Operational controls include personnel and user issues, contingency planning, incident handling, awareness and training, computer support and operations, and physical and environmental security issues. Technical controls include identification and authentication, logical access controls, audit trails, and cryptography. (See NIST Special Publication 800-12, *An Introduction to Computer Security: The NIST Handbook*, for in-depth discussion of these controls (http://csrc.nist.gov/publications/nistpubs/index.html).)

Please download and review
https://nvlpubs.nist.gov/nistpubs/Legacy/SP/nistspecialpublication800-50.pdf

Executive management: Organizational leaders need to fully understand directives and laws that form the basis for the security program. They also need to comprehend their leadership roles in ensuring full compliance by users within their units.

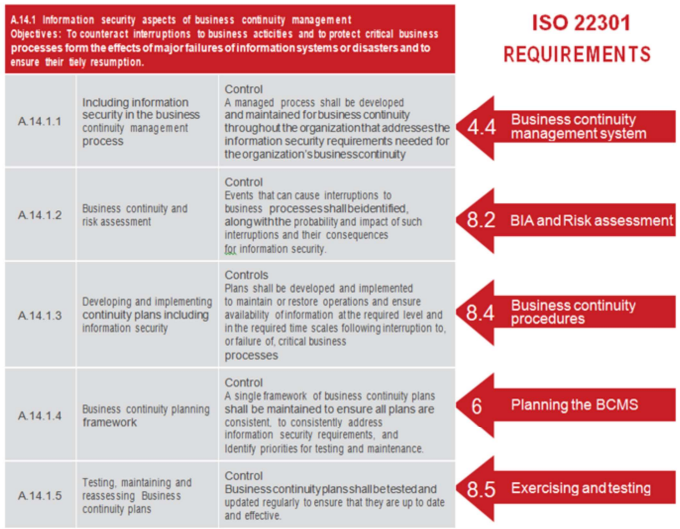
Security personnel (security program managers and security officers): These individuals act as expert consultants for their organization; therefore, they must be well educated on security policy and accepted best practices.

System owners: Owners must have a broad understanding of security policy and a high degree of understanding regarding security controls and requirements applicable to the systems they manage.

System administrators and IT support personnel: Entrusted with a high degree of authority over support operations critical to a successful security program, these individuals need a higher degree of technical knowledge in effective security practices and implementation.

Operational managers and system users: These individuals need a high degree of security awareness and training on security controls and rules of behavior for systems they use to conduct business operations.

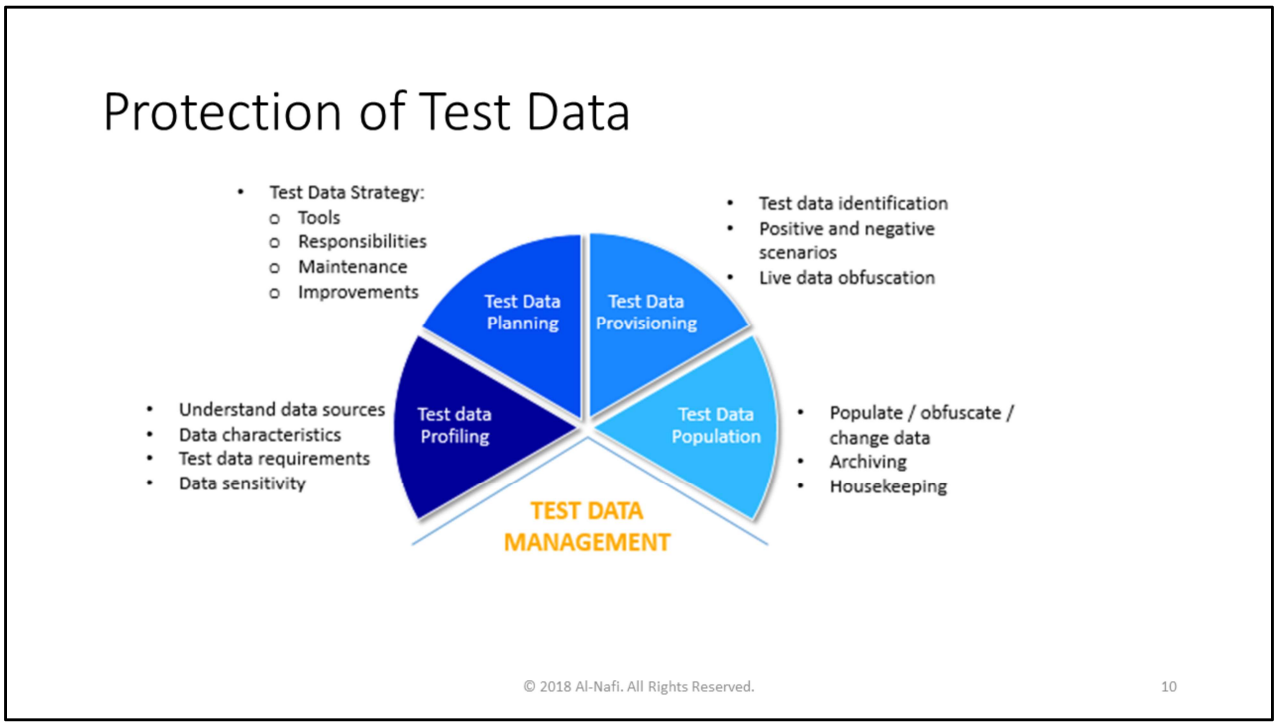
Disaster Recovery (DR) and Business Continuity (BC)



A.14.1 Information security aspects of business continuity management Objectives: To counteract interruptions to business activities and to protect critical business processes form the effects of major failures of information systems or disasters and to ensure their tiely resumption.			ISO 22301 REQUIREMENTS
A.14.1.1	Including information security in the business continuity management process	Control A managed process shall be developed and maintained for business continuity throughout the organization that addresses the information security requirements needed for the organization's business continuity	4.4 Business continuity management system
A.14.1.2	Business continuity and risk assessment	Control Events that can cause interruptions to business processes shall be identified, along with the probability and impact of such interruptions and their consequences for information security.	8.2 BIA and Risk assessment
A.14.1.3	Developing and implementing continuity plans including information security	Controls Plans shall be developed and implemented to maintain or restore operations and ensure availability of information at the required level and in the required time scales following interruption to, or failure of, critical business processes	8.4 Business continuity procedures
A.14.1.4	Business continuity planning framework	Control A single framework of business continuity plans shall be maintained to ensure all plans are consistent, to consistently address information security requirements, and identify priorities for testing and maintenance.	6 Planning the BCMS
A.14.1.5	Testing, maintaining and reassessing Business continuity plans	Control Business continuity plans shall be tested and updated regularly to ensure that they are up to date and effective.	8.5 Exercising and testing

© 2018 Al-Nafi. All Rights Reserved.

We will cover this in detail in later domains as it was covered to some extent in the EARLIER DOMAINS. We will also cover ISO 22301 Lead Implementation Course as well inshAllah.



14.3.1 Protection of test data

Control

Test data should be selected carefully, protected and controlled.

Implementation guidance

The use of operational data containing personally identifiable information or any other confidential information for testing purposes should be avoided. If personally identifiable information or otherwise confidential information is used for testing purposes, all sensitive details and content should be protected by removal or modification (see ISO/IEC 29101[26]).

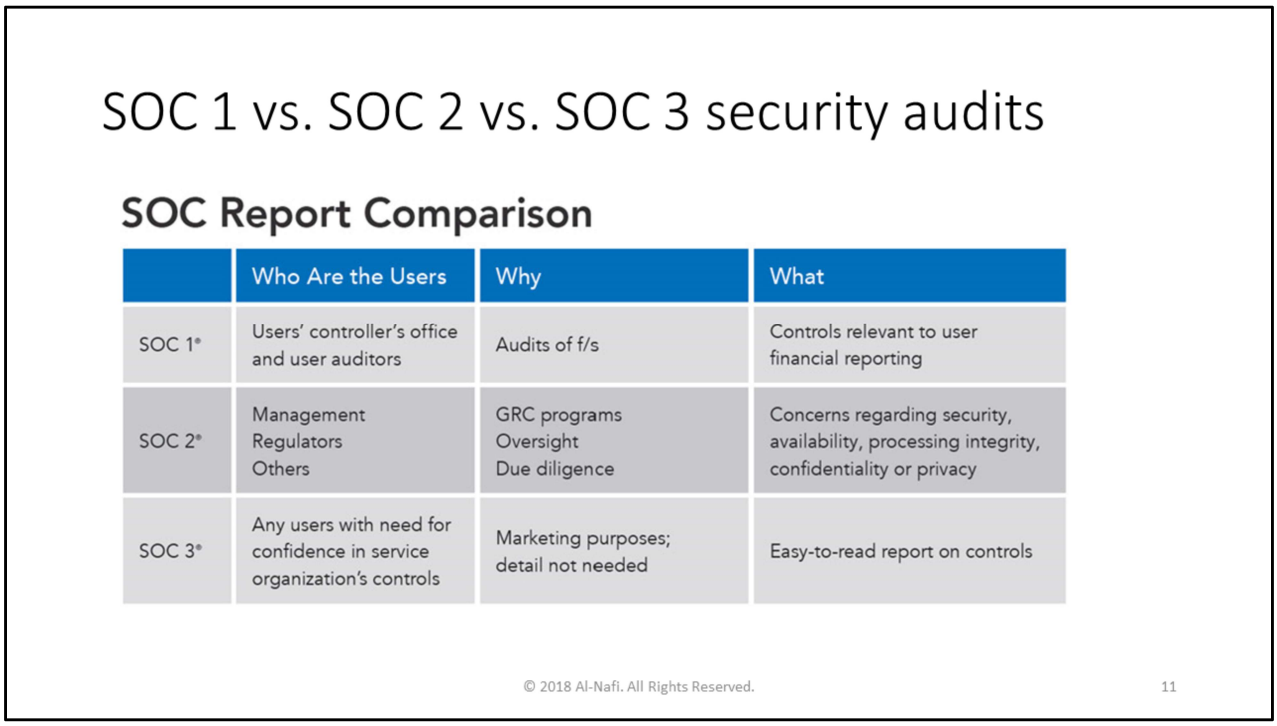
The following guidelines should be applied to protect operational data, when used for testing purposes:

a) the access control procedures, which apply to operational application systems, should also apply to test application systems;

b) there should be separate authorization each time operational information is copied to a test environment;

c) operational information should be erased from a test environment immediately after the testing is complete;
d) the copying and use of operational information should be logged to provide an audit trail.

Other information
System and acceptance testing usually requires substantial volumes of test data that are as close as possible to operational data.



Review this link. Joseph Kirkpatrick is an old friend of mine and he will be helping us achieve ISO 27001 certification along with SOC1, 2 and 3 down the line once we open our other business etc.

https://kirkpatrickprice.com/video/soc-1-vs-soc-2-vs-soc-3/

What's The Difference Between SOC 1, SOC 2, and SOC 3?

August 16, 2017/by Joseph KirkpatrickWhen it comes to SOC (Service Organization Control) reports, there are three different report types: SOC 1, SOC 2, and SOC 3. When considering which report fits your organization's needs, you must first understand what your clients require of you and then consider the areas of internal control over financial reporting (ICFR), the Trust Services Principles, and restricted use.
SOC 1 vs. SOC 2 vs. SOC 3

What Is a SOC 1 Report?
SOC 1 engagements are based on the SSAE 18 standard and report on the effectiveness of internal controls at a service organization that may be

relevant to their client's internal control over financial reporting (ICFR).

What Is a SOC 2 Report?

A SOC 2 audit evaluates internal controls, policies, and procedures that directly relate to the security of a system at a service organization. The SOC 2 report was designed to determine if service organizations are compliant with the principles of security, availability, processing integrity, confidentiality, and privacy, also known as the Trust Services Principles. These principles address internal controls unrelated to ICFR.

What Is a SOC 3 Report?

A SOC 3 report, just like a SOC 2, is based on the Trust Services Principles, but there's a major difference between these types of reports: restricted use. A SOC 3 report can be freely distributed, whereas a SOC 1 or SOC 2 can only be read by the user organizations that rely on your services. A SOC 3 does not give a description of the service organization's system, but can provide interested parties with the auditor's report on whether an entity maintained effective controls over its systems as it relates to the Trust Services Principles.

When trying to determine whether your service organization needs a SOC 1, SOC 2, or SOC 3, keep these requirements in mind:

Could your service organization affect a client's financial reporting? A SOC 1 would apply to you.

Does your service organization want to be evaluated on the Trust Service Principles? SOC 2 and SOC 3 reports would work.

Does restricted use affect your decision? SOC 1 and SOC 2 reports can only be read by the user organizations that rely on your services. A SOC 3 report can be freely distributed, used in many different applications.

Each of these reports must be issued by a licensed CPA firm, such as KirkpatrickPrice. We offer SOC 1, SOC 2, and SOC 3 engagements. To learn more about KirkpatrickPrice's SOC services, contact us today using the form below.

SOC 1 vs. SOC 2 vs. SOC 3 audits

A new course will be released as part of the audit track to provide walk through on how to perform SOC audits as per 1, 2 and 3 requirements. This course will be delivered in July 2020 inshAllah.

© 2018 Al-Nafi. All Rights Reserved.

جزاك اللهُ

To ask questions, Join the Al Nafi Official Group

https://www.facebook.com/groups/alnafi/

(This group is only for members to ask questions)

© 2018 Al-Nafi. All Rights Reserved.